LATIHAN LKS 2023 CYBERSECURITY

*The writeups by **SMKN2TGX** Team*



Presented by:

Bangkit Bayu Prasetyo
Fanji Rhamat

DAFTAR ISI

Pengaturan Infrastruktur & Penguatan Keamanan 2
- Autentikasi POST 2
- What's A Net Cat? 3
- Ini adalah hari ulang tahunku! 3

Capture The Flag(Attack) 3
- Ghost 3
- Web Gauntlet 2 4
- Login 7

Capture The Flag(Defense) 8
- What could this be? 8
- QR Code 9
- Smash the stack! 12
- The CVE 12

Pengaturan Infrastruktur & Penguatan Keamanan

Autentikasi POST

Situs web ini memerlukan autentikasi, melalui POST. Namun sepertinya seseorang telah merusak situs kami. Mungkin masih ada cara untuk melakukan proses autentikasi?
Link yang disediakan: http://165.227.106.113/post.php

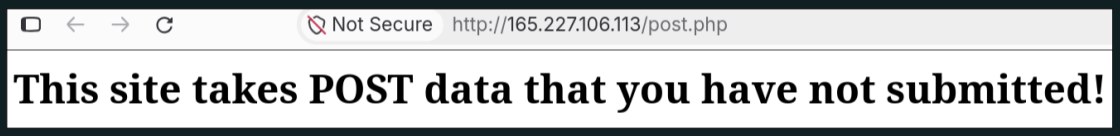
Deskripsi soal menyebutkan 2 hal penting: situs ini memvalidasi login lewat request POST, dan situs tersebut sudah dirusak. Berdasarkan kedua informasi tersebut, biasanya ada sisa kredensials yang seharusnya tidak ada di halaman publik. Jadi langkah pertamaku adalah melihat apa yang sebenarnya dikirim server saat halaman diakses biasa, sebelum mencoba POST apapun.

Perintah curl -i menampilkan header HTTP sekaligus isi body, sehingga semua informasi tetap terlihat di terminal.

```
[mars@ArchMars ~]$ curl -sS -i http://165.227.106.113/post.php
HTTP/1.1 200 OK
Server: nginx/1.4.6 (Ubuntu)
Date: Thu, 29 Oct 2026 01:59:32 GMT
Content-Type: text/html
Transfer-Encoding: chunked
Connection: keep-alive
X-Powered-By: PHP/5.5.9-1ubuntu4.22

<h1>This site takes POST data that you have not submitted!</h1><!-- username: admin | password: 71urlkufpsdnlkadsf -->
```

Di situlah letak “kerusakan”nya: developer meninggalkan kredensial login persis di dalam komentar HTML halaman tersebut, sesuatu yang seharusnya tidak dikirim ke client. Komentar HTML tidak terlihat saat halaman dirender di browser, tapi tetap ada di source/response mentah.



Pesan di halaman memberi tahu bahwa server mengharapkan data POST yang belum kita kirim. Dengan kredensial yang sudah didapat dari komentar tadi, langkah selanjutnya adalah mengirim keduanya sebagai field form-urlencoded standar (username dan password), sesuai nama yang tertulis di komentar itu sendiri.

```
[mars@ArchMars ~]$ curl -sS -i -X POST http://165.227.106.113/post.php -d "username=admin&password=71urlkufpsdnlkadsf"

HTTP/1.1 200 OK
Server: nginx/1.4.6 (Ubuntu)
Date: Thu, 29 Oct 2026 02:06:23 GMT
Content-Type: text/html
Transfer-Encoding: chunked
Connection: keep-alive
X-Powered-By: PHP/5.5.9-1ubuntu4.22

<h1>flag{p0st_d4t4_4ll_d4y}</h1>[mars@ArchMars ~]$
```

Server membalas dengan flag langsung di body response begitu field POST yang benar diterima.

What's A Net Cat?

Menggunakan netcat (nc) akan menjadi sangat penting.
Link yang disediakan: jupiter_challenges_picoctf.org dengan Port 25103

Error

Ini adalah hari ulang tahunku!

Saya mengirimkan 2 undangan ke semua teman saya untuk ulang tahun saya. Saya akan tahu jika mereka dicuri karena kedua undangan terlihat serupa dan mereka bahkan memiliki hash md5 yang sama, tetapi keduanya sedikit berbeda. Anda tidak akan percaya berapa lama saya menemukan kecurigaan. Bagaimanapun lihat apakah Anda diundang dengan mengirimkan 2 PDF ke situs web saya.
Link yang disediakan: http://mercury.picoctf.net:50970/

Error

Capture The Flag(Attack)

Ghost

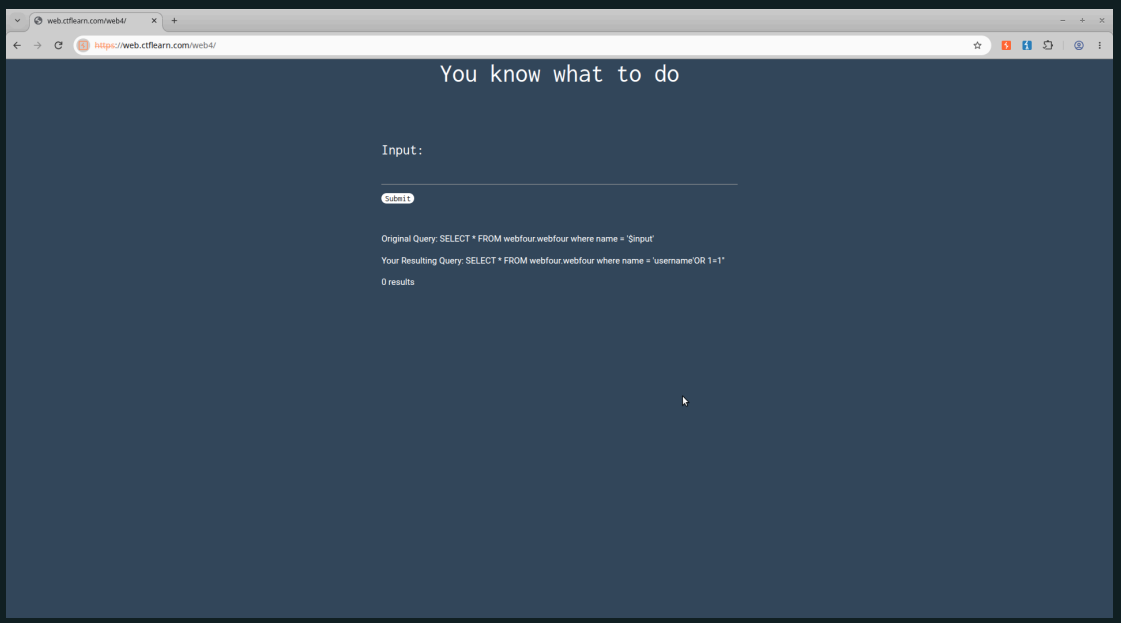
Overview

a. Ghost

Apakah Anda dapat membocorkan seluruh database menggunakan apa yang Anda ketahui tentang SQL Injections?

Link: https://web.ctflearn.com/web4/

Analisis



Referensi:
https://theswissbay.ch/pdf/Gentoomen%20Library/Security/SQL%20Injection%20Attacks%20and%20Defense.pdf

Sesuai dengan deskripsi soal yang diberikan web ini rentan terhadap SQLI, dimana input tidak memvalidasi input user dengan benar sehingga kita bisa menyusun payload menggunakan ‘ untuk memicu crash database,lalu ketika saya mencoba untuk menyusun payload dengan menggunakan username' OR '1'='1 server meresponse html yang terdapat html berikut:

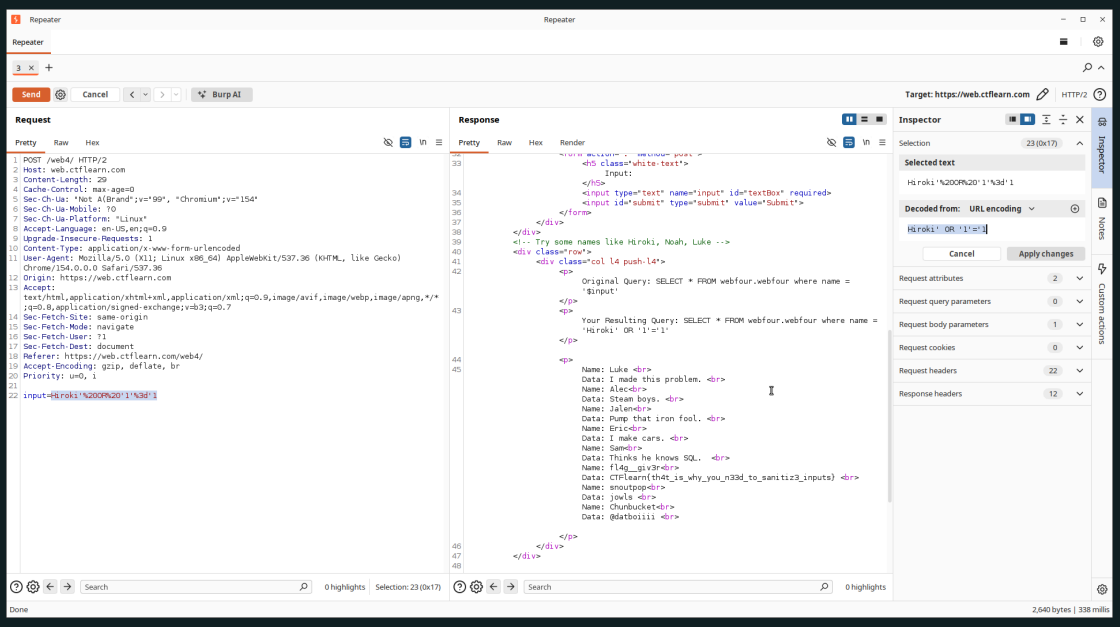
```
<!— Try some names like Hiroki, Noah, Luke —>
```

Eksploitasi

Berdasarkan petunjuk yang didapatkan, lalu susun payload berikut:

```
Hiroki' OR '1'='1
```

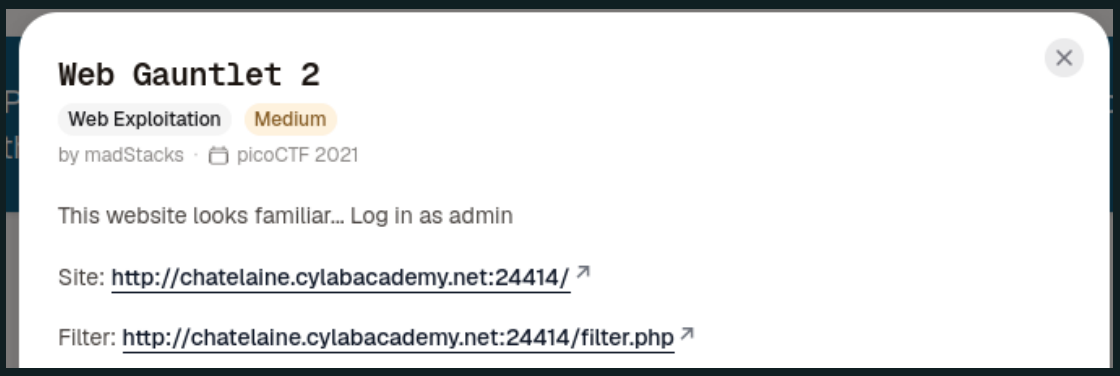
Setelah itu kirimkan payload nya dengan repeater burpsuite



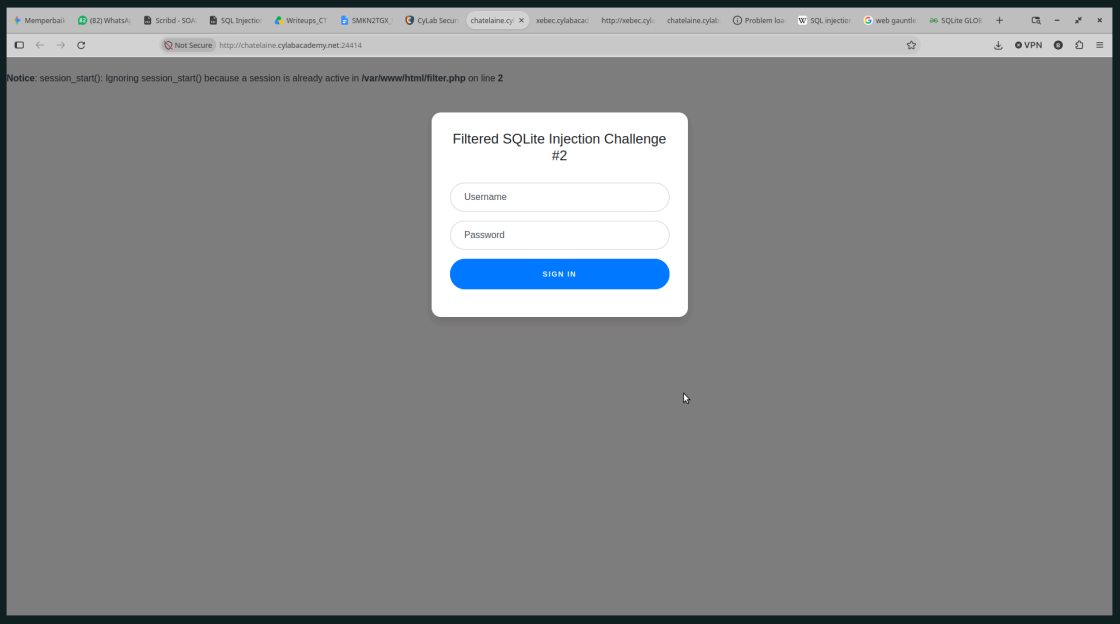
FLag
CTFlearn{th4t_is_why_you_n33d_to_sanitiz3_inputs}

Web Gauntlet 2

Overview



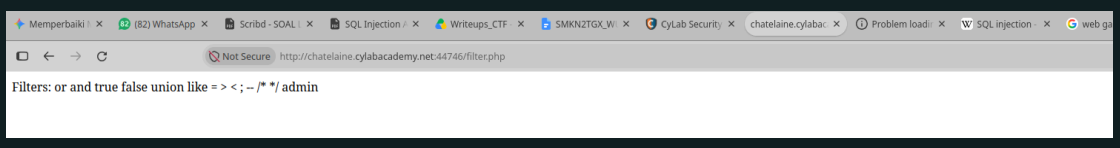
Analisis



Ketika baru pertama kali membuka websitenya langsung diberikan modal form untuk login, lalu terdapat error di phpnya yaitu

Notice: session_start(): Ignoring session_start() because a session is already active in **/var/www/html/filter.php** on line **2**

Artinya php mengabaikan session saat ini dan menggunakan sesi yang sudah ada, selanjutnya



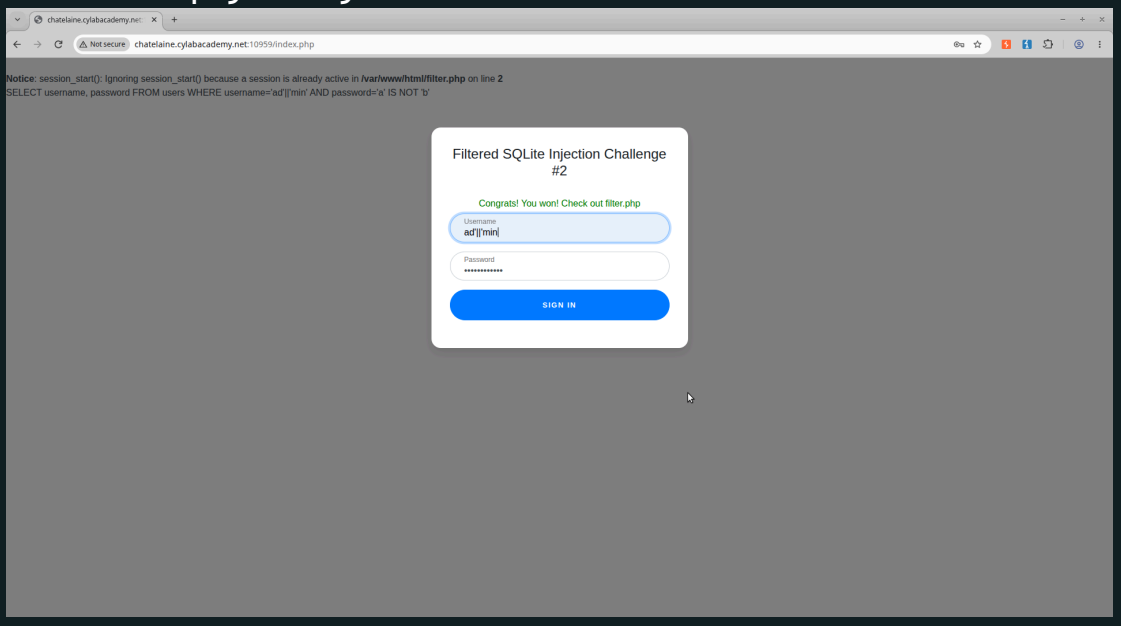
Filter hanya mengabaikan =,>,<,;,--,/* */ jadi kita bisa menggunakan ||

Eksploitasi

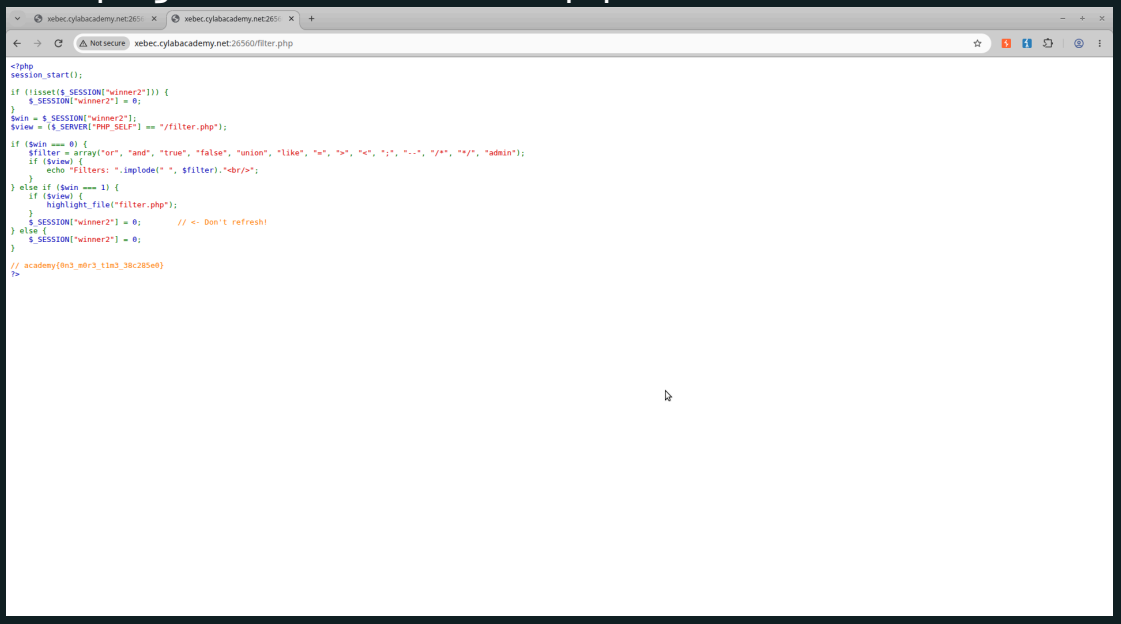
Susun payload

```
username=ad'||'min
password=a' IS NOT 'b
```

Lalu send payloadnya

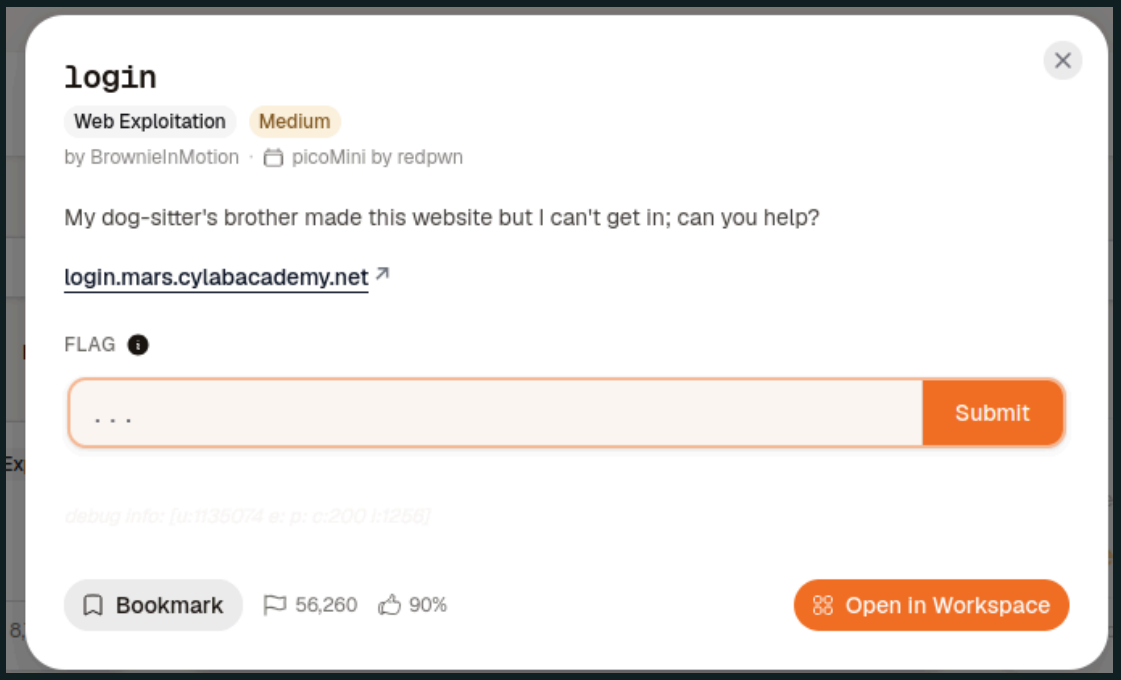


Lalu pergi ke halaman /filter.php

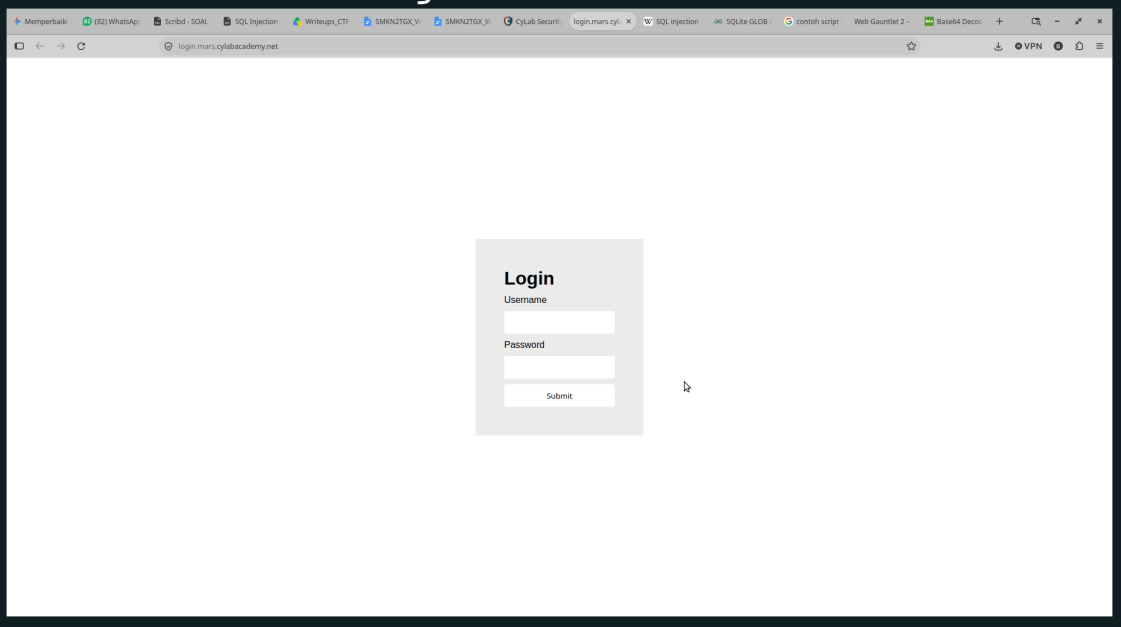


Flag
academy{0n3_m0r3_t1m3_38c285e0}

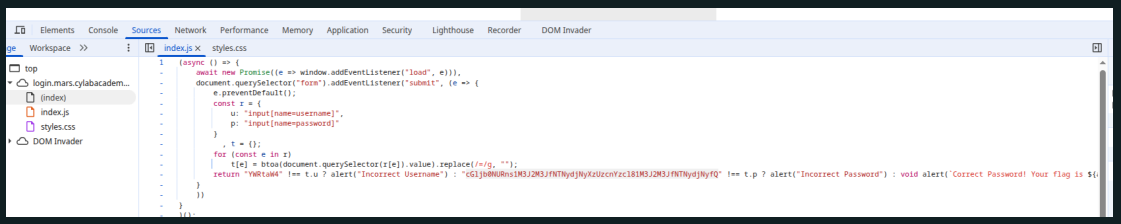
Login



Analisis
Diberikan website sebagai berikut:



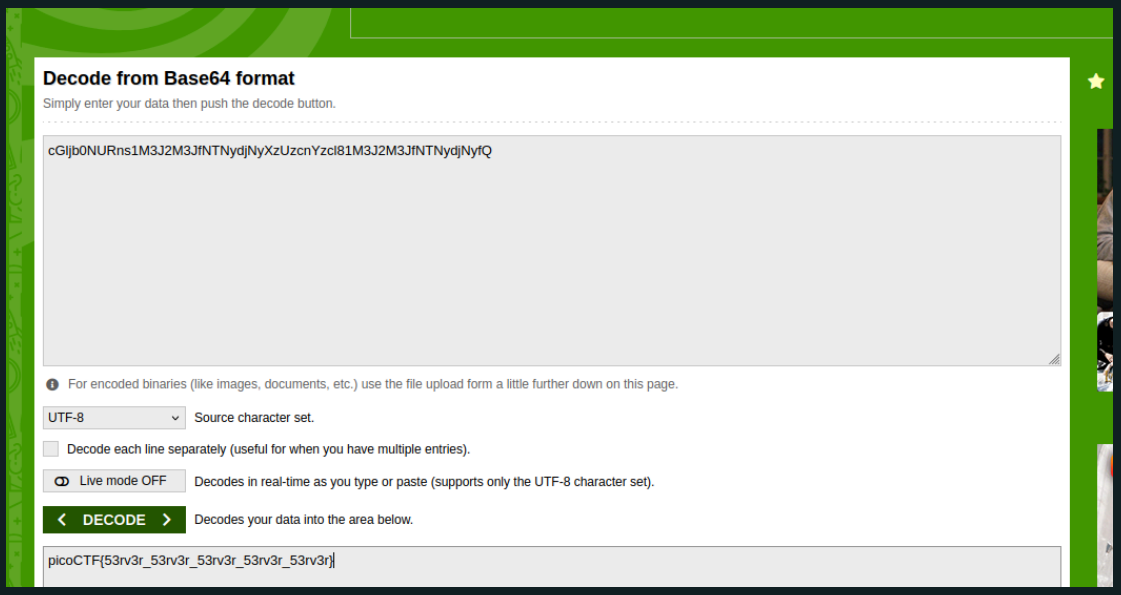
Pertama kali saya mencoba untuk melakukan SQLI, namun gagal karena terkena validasi input,setelah itu saya coba melakukan POST dan tangkap request menggunakan burpsuite, namun req tidak masuk, lalu saya berinisiasi untuk eksplorasi browser lebih dalam, lalu menemukan username yang sepertinya diencode menggunakan base64



Eksploitasi

Berdasarkan analisa yang kami lakukan, kami coba untuk decode token yang didapatkan dengan decoder base64 berikut:

https://www.base64decode.org/



Dan KABOOM, ternyata username tersebut adalah flagnya

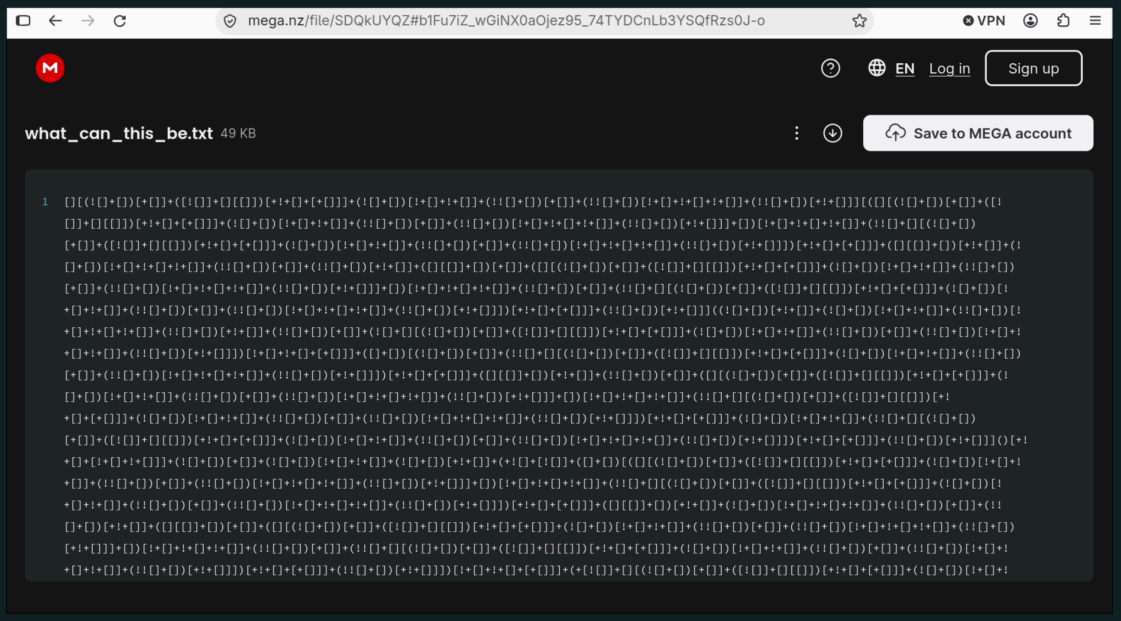
Flag
picoCTF{53rv3r_53rv3r_53rv3r_53rv3r_53rv3r}

Capture The Flag(Defense)

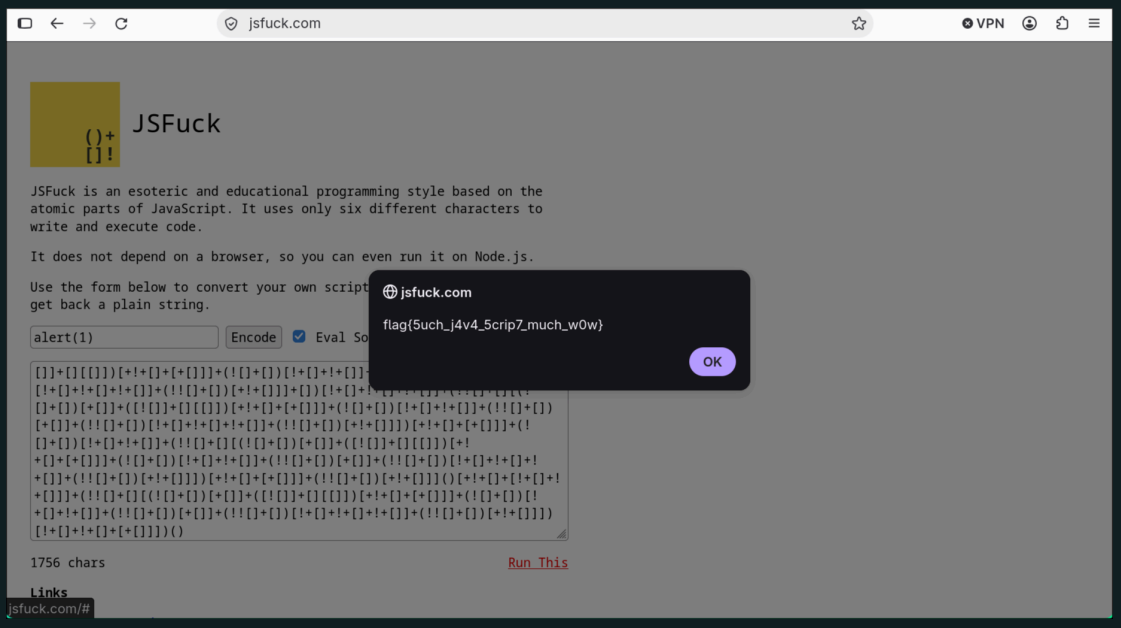
What could this be?

Sepertinya seseorang sangat menyukai **karakter khusus** atau mungkinkah itu berarti sesuatu yang lebih?
Link yang disediakan:
https://mega.nz/#!SDQkUYQZ!b1Fu7iZ_wGiNX0aOjez95_74TYDCnLb3YSQfRzs0J-o

Deskripsi soal memberikan hint bahwa ada sesuatu tentang “karakter khusus”, langkah pertama yang kuambil adalah membuka link tersebut.



Jika dilihat sejenak, akan terlihat seperti simbol-simbol acak. Namun, apabila diperhatikan terlihat bahwa isinya terdiri hanya dengan 6 simbol: []()+!
Keenam simbol tersebut termasuk dalam bahasa JSFuck.



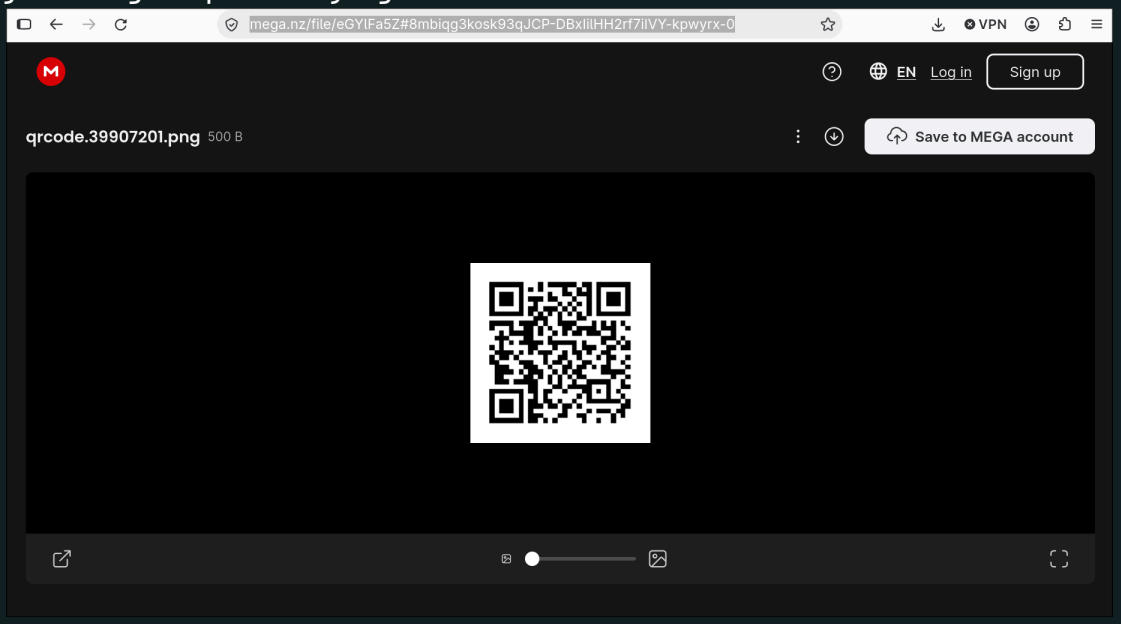
Benar saja, simbol acak tersebut berubah menjadi sebuah flag setelah kukonversi menggunakan JSFuck.

Flag{5uch_j4v4_5crip7_much_w0w}

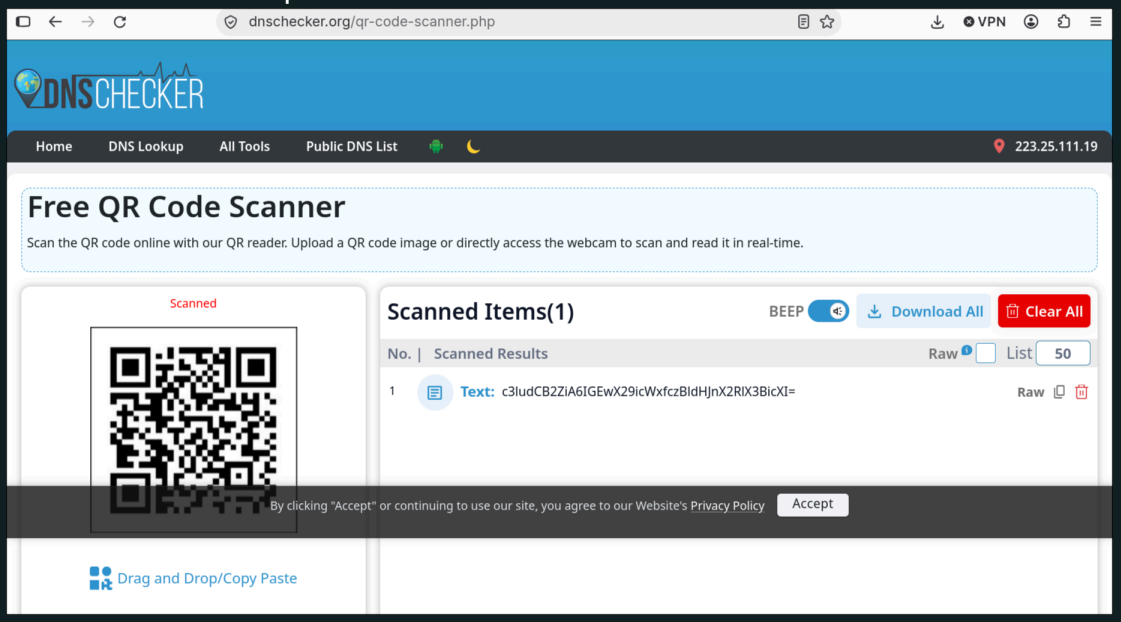
QR Code

Apakah Anda ingat sesuatu yang dikenal sebagai QR Code?
Gampang kan?!
Link yang disediakan:
https://mega.nz/file/eGYlFa5Z#8mbigg3kosk93qJCP-DBxIilHH2rf7iIVY-kpwyrx-0

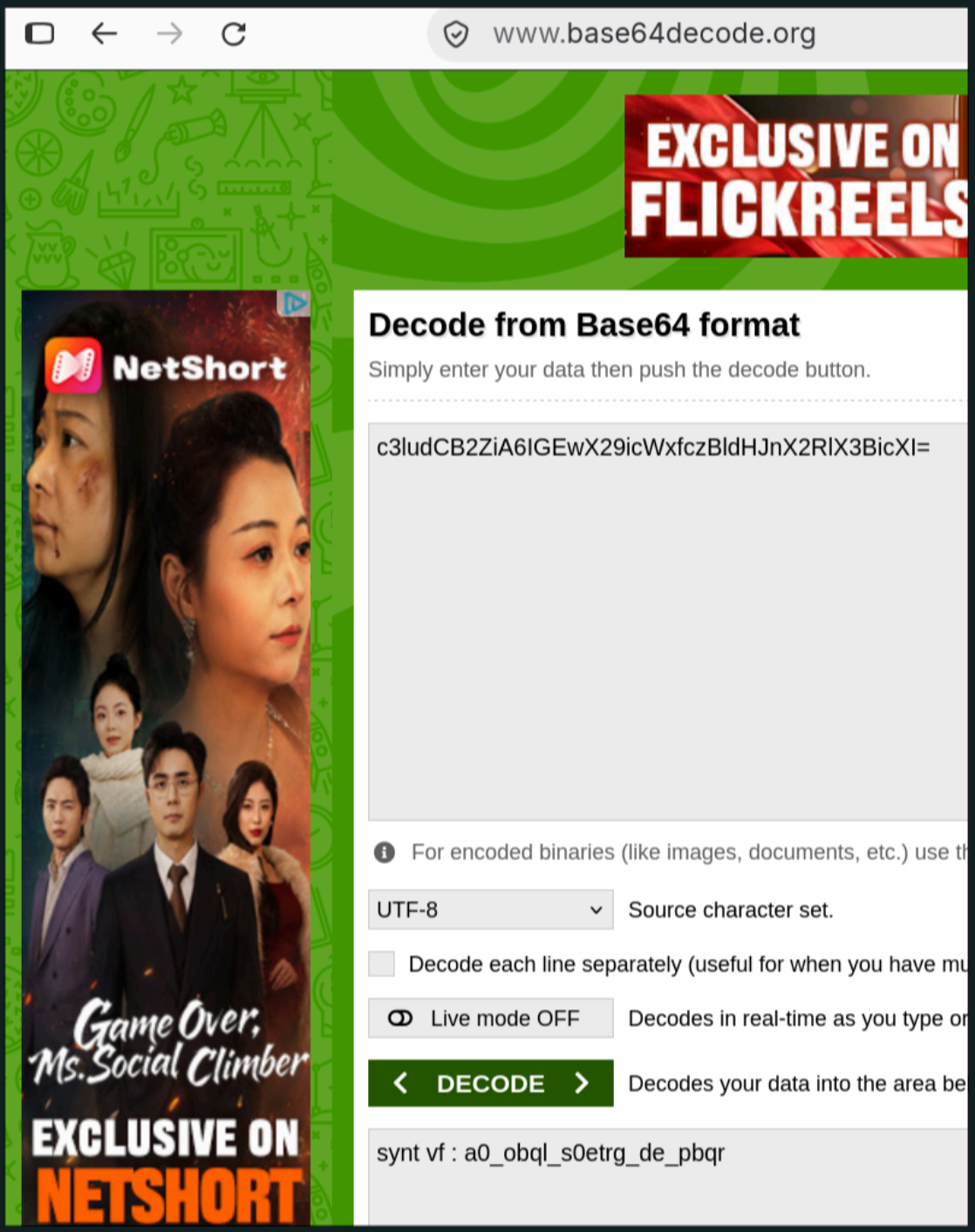
Deskripsi tidak memberikan hint apapun selain menyebutkan QR Code, jadi langkah pertama yang kulakukan adalah membuka link.



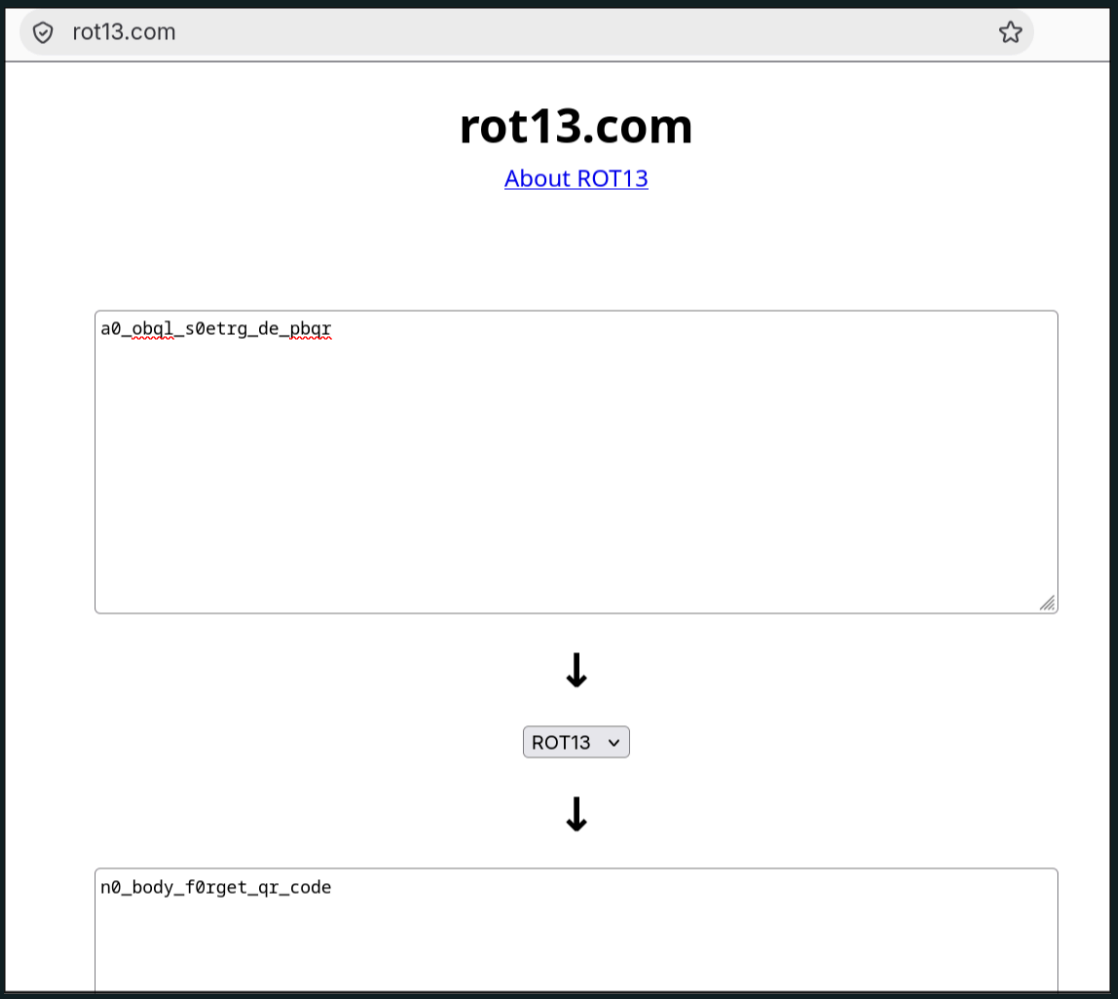
Disajikan sebuah QR Code oleh link tersebut, setelah kupindai diberikan hasil seperti berikut:



c3ludCB2ZiA6IGEwX29icWxfczBldHJnX2RlX3BicXI=
Terlihat seperti kode mentahan dari Base64, jadi kucoba decode kode dari Base64 tersebut.



“synt vf : a0_obql_s0etrg_de_pbqr”
Sepertinya hasil tersebut masih belum bisa digunakan, lalu coba kususun huruf-huruf tersebut dengan ROT13(Sebuah algoritme sederhana yang digunakan untuk menggeser setiap huruf sebanyak 13 posisi dalam alfabet Latin.



“n0_body_f0rget_qr_code”
Dengan bantuan algoritme ROT13, kutemukan flagnya.

Flag:
Flag{n0_body_f0rget_qr_code}

Sumber Referensi:
https://7rocky.github.io/en/ctf/ctflearn/miscellaneous/qr-code/

Smash the stack!

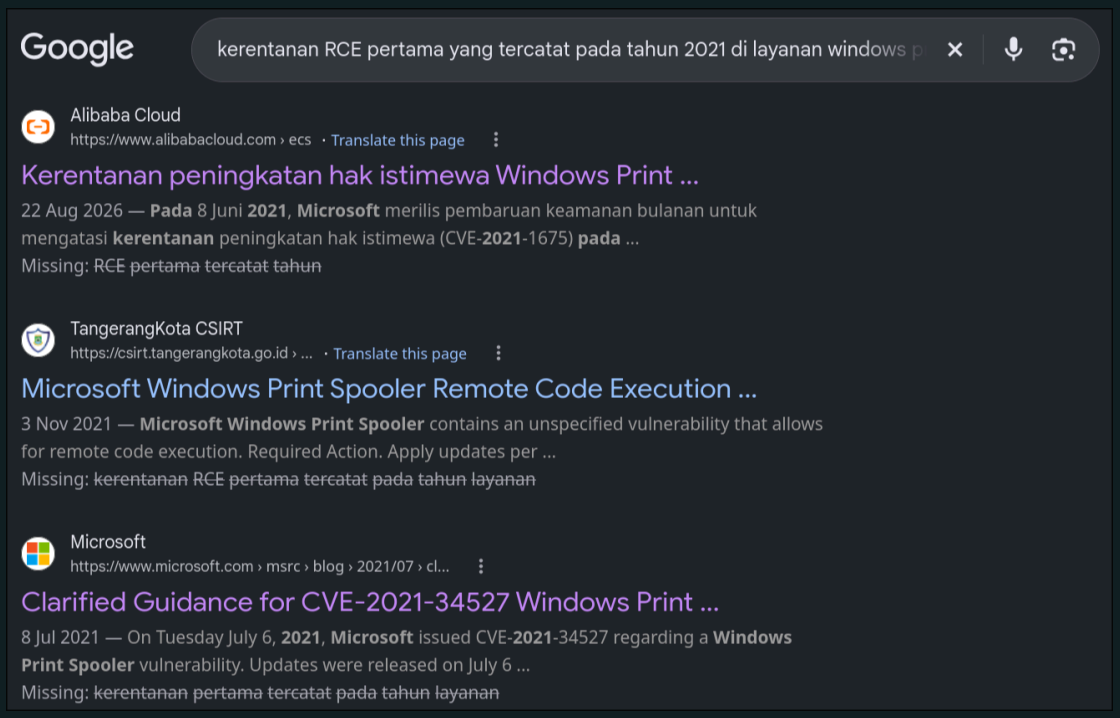
Mari kita mulai dengan sederhana, dapatkah Anda meluapkan buffer yang benar? Anda dapat melihat sumber di sini. Dapat mengakses dengan menggunakan: nc saturn.picoctf.net 51110
picoCTF{ov3rfl0ws_ar3nt_that_bad_8ba275ff}

Error

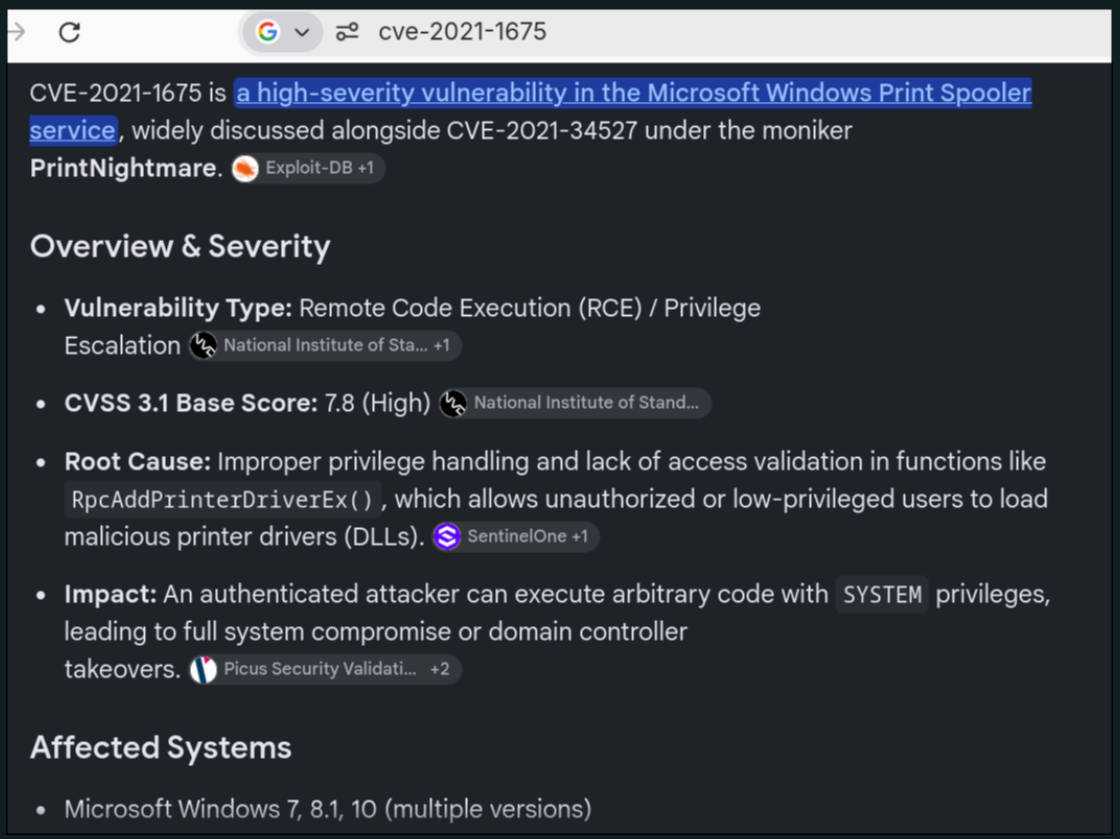
The CVE

picoCTF{CVE-XXXX-XXXXX} ganti dengan XXXX-XXXXX dengan angka untuk kerentanan yang cocok.
naCVE yang kami cari adalah kerentan remote code execution (RCE) pertama yang tercatat pada tahun 2021 di Layanan Windows Print Spooler, yang tersedia diseluruh versi desktop dan server sistem

operasi Windows. Layanan ini digunakan untuk mengelola printer dan server cetak.

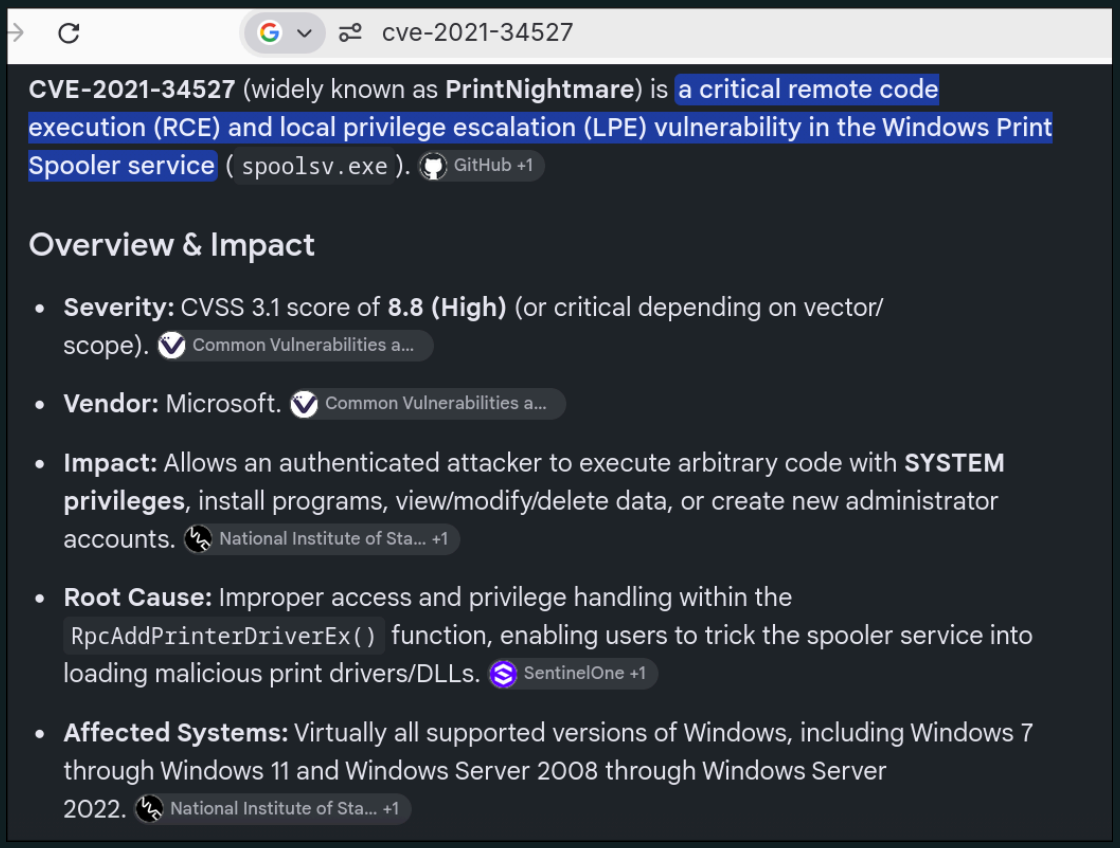


Dengan informasi yang didapat dari deskripsi, aku bisa mencari yang dimaksud melalui internet. Setelah mendapatkan target yang lebih spesifik; CVE-2021-1675 dan CVE-2021-34527, kucari satu persatu dari masing-masing CVE.



Untuk CVE-2021-1675, dijelaskan bahwa memang itu termasuk kerentanan RCE yang dipermasalahkan oleh Microsoft. Namun berdasarkan deskripsi

soal, CVE yang dimaksud itu berpengaruh ke semua versi Windows, sementara itu CVE-2021-1675 hanya mempengaruhi versi 7, 8.1, dan 10. Dengan itu, kuputuskan untuk mencari informasi dari yang satunya, CVE-2021-34527.



“Affected Systems: Virtually all supported versions of Windows, including Windows 7 through Windows 11 and Windows Server 2008 through Windows Server 2022.”
Pada dasarnya, CVE-2021-34527 berpengaruh terhadap seluruh versi Windows, termasuk Windows 7 hingga Windows 11 dan Windows Server 2008 hingga Windows Server 2022.
Jadi apabila disimpulkan, CVE yang dimaksud dalam soalnya adalah 34527.
picoCTF{CVE-[tahun kerentanan]-[kerentanan]}

flag:
picoCTF{CVE-2021-34527}